

Name:-Siddhi Aadekar

Inter id:-284

Task:- Threat Intelligence

ATLAS (Adversarial Machine Learning / Agentic AI) Matrix

The ATLAS Matrix below shows the progression of tactics used in attacks as columns from left to right, with ML techniques belonging to each tactic below. & indicates an adaption from ATT&CK. Click on the blue links to learn more about each item, or search and view ATLAS tactics and techniques using the links at the top navigation bar. View the ATLAS matrix highlighted alongside ATT&CK Enterprise techniques on the [ATLAS Navigator](#).

1. Reconnaissance

This is the initial phase where an attacker gathers information about the target AI system and its surrounding environment. The goal is to understand the system's architecture, data sources, security controls, and potential vulnerabilities without directly interacting with it.

- **Technique 1: Open-Source Intelligence (OSINT) Gathering:**
 - **Explanation:** Attackers use publicly available information to learn about the target. This can include finding academic papers published by the development team, job postings that reveal the specific AI models or frameworks being used (e.g., TensorFlow, PyTorch), and even social media posts from employees that might disclose details about the project.
- **Technique 2: Model Card Evasion:**
 - **Explanation:** Many organizations publish "model cards" to document their AI models' purpose, performance, and limitations. An attacker can study these cards to find out what the model is designed to do, what its known failure modes are, and what data it was trained on, which can inform later attacks.
- **Technique 3: Public Data Leak Analysis:**
 - **Explanation:** Attackers search for publicly accessible data leaks, data breaches, or even improperly secured cloud storage buckets that might contain a subset of the data used to train the target model. Access to this data is invaluable for crafting a successful adversarial attack.

Step-by-step Procedure for Public Data Leak Analysis:

1. **Identify Target:** The attacker chooses a specific AI system, for instance, a company's facial recognition software.
2. **Keyword Search:** The attacker uses search engines and specialized data breach search tools to look for keywords related to the company and the model. They might

search for "company_name training data," "facial recognition dataset," or specific file formats like .csv, .json, or image directories that could contain training data.

3. **Data Acquisition:** If a data leak is found, the attacker downloads the data.
4. **Analysis:** The attacker analyzes the downloaded data to understand its structure, the types of images or data points it contains, and any sensitive information. This information is then used to create a more effective adversarial attack.

2. Resource Development

In this phase, the attacker prepares the tools and infrastructure needed for the attack. This is about building the "arsenal" to launch the attack, which can include creating fake accounts, setting up command and control servers, and developing custom malware.

- **Technique 1: Adversarial Sample Generation Toolkit:**
 - **Explanation:** Attackers don't always need to build adversarial samples from scratch. They can download and use open-source toolkits like foolbox, ART (Adversarial Robustness Toolbox), or CleverHans to generate sophisticated adversarial examples that can fool the target model.
- **Technique 2: Agentic AI Impersonation:**
 - **Explanation:** An attacker might develop a sophisticated AI agent that is designed to mimic a legitimate user or another AI agent. This "Trojan horse" agent can then be used to interact with the target system, learn its behavior, and eventually execute a malicious payload.
- **Technique 3: AI Model Training:**
 - **Explanation:** The attacker may train a "proxy model" that mimics the behavior of the target AI model. By training their own model on publicly available data or data obtained during reconnaissance, they can test various attack techniques against their proxy model before attempting them against the real system, reducing the risk of detection.

3. Initial Access

This is the first point of entry into the target environment. The goal is to gain a foothold, which can be achieved through various means.

- **Technique 1: Phishing for API Keys:**
 - **Explanation:** Attackers can craft highly targeted phishing emails designed to trick an AI engineer or developer into revealing their API keys, which are credentials used to access and interact with the AI model. With an API key, the attacker can make queries to the model as if they were a legitimate user.

- **Technique 2: Supply Chain Compromise (ML Libraries):**
 - **Explanation:** Many AI applications rely on third-party libraries and frameworks. An attacker could inject malicious code into a popular open-source library that is then used by the target company. The malicious code could be designed to exfiltrate data, create a backdoor, or modify the AI model's behavior.
- **Technique 3: Weak API Authentication:**
 - **Explanation:** Some AI models are exposed through an API with weak or no authentication. An attacker can simply access the API endpoint and start sending queries without needing any special credentials, effectively gaining free access to the model.

Step-by-step Procedure for Phishing for API Keys:

1. **Target Identification:** The attacker identifies an AI developer at the target company through LinkedIn or other professional networking sites.
2. **Email Crafting:** The attacker creates a convincing phishing email, possibly impersonating a manager or a member of the IT department. The email might claim that there is a "security audit" or that the developer needs to "update their API key" by clicking a link.
3. **Credential Harvesting Site:** The link in the email leads to a fake website that looks identical to the company's internal login page or a developer portal.
4. **Credential Capture:** When the developer enters their API key and other credentials on the fake site, the attacker captures them.
5. **Access:** The attacker now has a valid API key and can interact with the AI model as if they were the legitimate developer.

4. AI Model Access Execution

Once the attacker has initial access, this phase is about executing the attack against the AI model itself. This is where the core adversarial techniques are used.

- **Technique 1: Adversarial Sample Execution:**
 - **Explanation:** Using the adversarial samples created in the "Resource Development" phase, the attacker feeds them into the target model's input. The goal is to cause the model to misclassify the input in a specific way. For example, an attacker might add a small, imperceptible noise to an image of a stop sign, causing the model to classify it as a "yield" sign.
- **Technique 2: Data Poisoning:**

- **Explanation:** If the attacker has the ability to influence the training data (e.g., through a supply chain attack or by compromising a data collection pipeline), they can inject malicious data points into the training set. This "poisoned" data can cause the model to learn incorrect patterns, leading to specific, predictable failures once the model is deployed.
- **Technique 3: Model Inversion Attack:**
 - **Explanation:** This attack is used to reconstruct the private training data used to train the model. By querying the model with specific inputs and observing its outputs, an attacker can infer information about the data it was trained on. This is a significant privacy risk.

5. Persistence

The goal here is to maintain a foothold in the compromised system even if the initial point of entry is closed.

- **Technique 1: Backdoor Insertion:**
 - **Explanation:** An attacker might insert a "backdoor" into the AI model itself. This is a hidden, malicious behavior that is only activated when a specific trigger is met. For example, a facial recognition model might be backdoored to grant access to a system only when a specific, rare image is presented to it.
- **Technique 2: Compromised Container/VM:**
 - **Explanation:** Many AI models run within virtual machines (VMs) or containers (e.g., Docker). An attacker could compromise the container or VM hosting the AI model, allowing them to gain control of the underlying infrastructure and ensure their access persists even if the AI model itself is updated.
- **Technique 3: Scheduled Task Modification:**
 - **Explanation:** If the attacker has access to the underlying operating system, they can modify a scheduled task or cron job that is responsible for running the AI model or a data pipeline. This can be used to periodically exfiltrate data or to re-establish a backdoor if it is ever removed.

6. Privilege Escalation

After gaining initial access, the attacker seeks to elevate their privileges within the system to gain more control.

- **Technique 1: API Key Reuse:**
 - **Explanation:** An API key that provides access to a specific AI model might also have permissions to other, more sensitive services within the company's

cloud environment. An attacker can use this key to access these other services, effectively escalating their privileges.

- **Technique 2: Kernel/Driver Vulnerabilities:**

- **Explanation:** If the AI model is running on a server with an unpatched kernel or a vulnerable device driver (e.g., for a GPU), an attacker can exploit these vulnerabilities to gain root or administrator-level access to the host machine.

- **Technique 3: Misconfigured Permissions:**

- **Explanation:** Misconfigured file permissions or network settings can allow a low-privileged user or process to access a highly privileged resource. For example, if the AI model runs with the same permissions as a critical system service, an attacker can exploit this to gain control of the service.

7. Defense Evasion

Attackers use this tactic to avoid detection by security tools and defenders.

- **Technique 1: AI-based Evasion:**

- **Explanation:** The attacker uses an AI model of their own to generate adversarial examples that are specifically designed to bypass the target's defenses. For example, they might use a generative adversarial network (GAN) to create highly realistic fake images that are hard for both humans and security systems to detect.

- **Technique 2: Model Obfuscation:**

- **Explanation:** An attacker can use techniques to make their adversarial attacks less obvious. For example, instead of adding a large, noticeable noise to an image, they might make many smaller, more subtle changes that are harder for a human or a defense mechanism to notice.

- **Technique 3: Log Tampering:**

- **Explanation:** If the attacker has access to the system's logs, they can modify or delete entries to hide their activity and prevent a security incident from being discovered.

8. Credential Access

The goal here is to steal credentials, such as usernames, passwords, and API keys, to gain further access to systems.

- **Technique 1: Keylogging in Development Environments:**

- **Explanation:** An attacker can install a keylogger on a developer's workstation to capture their credentials as they are typed. This is particularly effective if the developer has access to the AI model's code, data, and production environment.
- **Technique 2: Credential Dumping from Memory:**
 - **Explanation:** If the attacker has administrator privileges on the host machine, they can use tools to dump the contents of memory and search for sensitive credentials that are stored there in plaintext.
- **Technique 3: API Key Extraction from Code:**
 - **Explanation:** Many developers inadvertently hardcode API keys or other credentials directly into their code. An attacker can search for these keys in source code repositories, configuration files, or within the deployed application itself.

9. Discovery

Once inside, the attacker tries to learn more about the internal network and systems.

- **Technique 1: Data Source Identification:**
 - **Explanation:** The attacker tries to find out where the AI model gets its data from. This could be a database, a data lake, or a streaming service. Finding the data source can be a goldmine for further attacks.
- **Technique 2: AI Model Topology Mapping:**
 - **Explanation:** The attacker tries to understand how different AI models are connected and how data flows between them. This can help them find the most vulnerable points in the system.
- **Technique 3: Host and Network Enumeration:**
 - **Explanation:** The attacker uses standard network scanning tools to discover other hosts and services on the network that they can potentially target.

10. Collection

This phase is about gathering valuable data from the compromised system.

- **Technique 1: Training Data Exfiltration:**
 - **Explanation:** The attacker steals the training data used for the AI model. This data is often highly sensitive, containing personal information, proprietary business data, or intellectual property.
- **Technique 2: Model Weights Exfiltration:**

- **Explanation:** The "weights" of an AI model are the learned parameters that make the model work. Stealing the model weights is equivalent to stealing the intellectual property of the company that developed the model.
- **Technique 3: Inference Log Collection:**
 - **Explanation:** An attacker can collect the logs of the model's predictions. These logs can contain sensitive data that was fed into the model by legitimate users, such as medical records or financial information.

11. AI Attack Staging

This is the final preparation phase before the main attack is launched.

- **Technique 1: Adversarial Sample Optimization:**
 - **Explanation:** The attacker refines their adversarial samples based on the knowledge they've gained about the target model and its defenses. They might use a proxy model to test and optimize their samples to ensure they are highly effective.
- **Technique 2: Backdoor Trigger Refinement:**
 - **Explanation:** If the attacker has inserted a backdoor, they will test the trigger to make sure it works as expected and is not easily detectable.
- **Technique 3: Malicious Agent Deployment:**
 - **Explanation:** The attacker deploys a malicious AI agent or a piece of malware that is designed to interact with the target system in a specific way to achieve the attack's goal.

12. Command and Control

This tactic describes how the attacker communicates with and controls their compromised resources within the target environment.

- **Technique 1: DNS Tunneling:**
 - **Explanation:** An attacker can use DNS queries to exfiltrate data and control their malicious tools. This is often an effective technique because DNS traffic is often not heavily monitored by security tools.
- **Technique 2: Legitimate API Use:**
 - **Explanation:** An attacker can use a compromised API key to communicate with their own command and control server. The traffic will look like legitimate API traffic from the target system, making it very hard to detect.
- **Technique 3: Agentic AI Communication Channels:**

- **Explanation:** The attacker can use the same communication channels as the legitimate AI agents in the system to control their malicious agent. This makes their activity blend in with the normal operation of the system.

Step-by-step Procedure for Legitimate API Use:

1. **Compromise API Key:** The attacker gains access to a valid API key through phishing or other means.
2. **Establish C2 Server:** The attacker sets up a C2 server that is designed to look like a legitimate service endpoint.
3. **Use API for Exfiltration:** The attacker sends a request to the legitimate AI model's API, but instead of providing a valid input, they craft a payload that uses the API to send data to their C2 server. For example, they might use the API's query parameters to encode the data they want to exfiltrate.
4. **Receive Commands:** The attacker's C2 server can also send commands back to the malicious tools within the target system using the same API. The commands can be encoded within the API responses.

13. Exfiltration

The goal here is to steal and transfer data out of the target network.

- **Technique 1: Data Compression and Encryption:**
 - **Explanation:** The attacker compresses and encrypts the stolen data to make it smaller and harder to detect. This makes it easier to transfer and less likely to be flagged by security tools.
- **Technique 2: Data over AI Model Output:**
 - **Explanation:** The attacker can encode the stolen data into the output of the AI model. For example, if the model outputs text, the attacker can craft an input that causes the model to output a string that contains the exfiltrated data.
- **Technique 3: Staged Exfiltration:**
 - **Explanation:** Instead of exfiltrating all the data at once, the attacker might exfiltrate it in small, regular chunks to avoid being detected by security tools that look for large data transfers.

Step-by-step Procedure:

1. **Gain Access:** The attacker first needs to gain a foothold in the system and access to the AI model's API. This could be through a compromised API key, a vulnerable

container, or any of the methods described in the "Initial Access" and "Privilege Escalation" phases.

2. **Collect and Encode Data:** The attacker identifies the data they want to steal (e.g., a customer list, a portion of the training data). They then encode this data into a format that can be easily embedded into the AI model's output. For example, they might convert the data into a string of numbers or characters.
3. **Craft the Input:** The attacker crafts a specific input query for the AI model. This input is not designed to be a legitimate request. Instead, it is a specially crafted "adversarial query" that, when processed by the model, will cause the model to output a response that contains the encoded, stolen data. This is often a trial-and-error process, as the attacker needs to find the exact query that will produce the desired output.
4. **Execute the Query and Capture Output:** The attacker sends the crafted query to the AI model's API. The model, thinking it's a legitimate request, processes the input and returns a response. The attacker intercepts this response, which now contains the exfiltrated data.
5. **Decode and Reconstruct:** The attacker takes the captured output, extracts the encoded string, and decodes it back into the original data format, successfully completing the exfiltration without arousing suspicion from network monitoring tools.

14. Impact

This is the final stage where the attacker achieves their ultimate objective.

- **Technique 1: Model Impairment:**
 - **Explanation:** The attacker's goal is to degrade the performance of the AI model, making it less accurate or even unusable. This can be achieved through data poisoning, model corruption, or denial-of-service attacks.
- **Technique 2: Intellectual Property Theft:**
 - **Explanation:** The attacker steals the proprietary training data, the model weights, or the code used to train the model. This can cause significant financial and competitive damage to the target organization.
- **Technique 3: Automated Decision Manipulation:**
 - **Explanation:** The attacker manipulates the output of the AI model to cause specific, malicious actions to be taken. For example, an attacker could manipulate an AI-powered financial trading system to make a bad trade, causing a significant financial loss.

Step-by-step Procedure:

1. **Identify High-Impact Target:** The attacker chooses an AI model whose decisions have significant consequences. This could be a stock trading algorithm, a medical diagnosis tool, or an autonomous vehicle's navigation system.
2. **Develop the Adversarial Tactic:** The attacker uses their knowledge of the model's vulnerabilities to develop a specific adversarial tactic. For example, for a stock trading algorithm, they might find a way to manipulate the news headlines or market data that the AI uses to make decisions. For a self-driving car, they might create a sticker or a small change on a road sign that causes the car's vision system to misinterpret it.
3. **Deploy the Attack:** The attacker executes their plan. For a financial system, this might involve injecting fake news or manipulating public data feeds that the algorithm consumes. For a physical system, this could involve placing a malicious object in the environment.
4. **Observe and Exploit the Outcome:** The attacker then observes the results of their manipulation. In the case of the financial system, they would watch for the desired market action and then exploit it for profit. In the case of the autonomous vehicle, they would observe the car's incorrect reaction, which could lead to an accident. The attacker has successfully weaponized the AI's decision-making process to achieve a malicious goal.